

Industrial Security (Bachelor)

Solution Sheet – Section 06 Vulnerabilities and Assessment

Model answers and rubric hints. The aim is defensible reasoning, not a single “right” string – accept any solution that names a real tool, cites a real advisory, and addresses the OT-specific risk the question targets.

Exercise 6.1 – CVSS v3.1 Environmental Score

Base vector: **CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H**, base score **9.8 (Critical)**.

Justified environmental modifiers:

- **MAV:A** – the PLC is not Internet-reachable; access requires being on the engineering VLAN.
- **MAC:H** – the attacker must first compromise one of two named engineering workstations and traverse a firewall rule.
- **MPR:L** – those workstations require domain credentials; the bar is no longer “no privileges”.
- **CR:L** – the dosing recipe is not a trade secret.
- **IR:H** – a tampered batch is the dominant business risk (ruined product, regulatory exposure).
- **AR:M** – a controller outage costs a shift, not the plant.

Modified impact metrics remain **MC:H/MI:H/MA:H**. Full environmental vector: **CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H/MAV:A/MAC:H/MPR:L/MC:H/MI:H/MA:H/CR:L/IR:H/AR:M**. The FIRST calculator returns an environmental score in the **6.5–7.2** range (High, not Critical).

Patch priority: downgrade from emergency-out-of-band to the next maintenance window, *provided* the firewall rule and workstation EDR controls are verified – the integrity-loss path remains the deciding factor. Accept any reasoned answer in this range; penalise environmental vectors that flip Confidentiality requirements to H without justification.

Exercise 6.2 – 200 PLCs vs. CISA in 24 Hours

Required asset fields: vendor, exact model / part number, hardware revision, firmware version (and bootloader where applicable), zone / cell, owner, criticality tier. Without firmware version no CVE match is possible.

Feeds: CISA ICS advisories (HTML and CSAF JSON since 2023), vendor PSIRT pages (Siemens ProductCERT, Rockwell PSIRT, Schneider CPCERT, ABB CERT, Mitsubishi PSIRT – each publishes its own RSS/JSON), NVD JSON 2.0 API for canonical CVE records.

Tooling chain: ideally the asset inventory already lives in a passive monitoring product (Claroty CTD, Nozomi Guardian, Dragos Platform, Tenable.ot, Forescout SilentDefense, or Microsoft Defender for IoT) that ingests CISA / vendor feeds and produces a matched report automatically. Where that does not exist, script the matching: pull the CSAF feed, normalise vendor / model / firmware strings, join against the spreadsheet, output a ranked CSV.

What goes wrong: (a) firmware-naming mismatches (e.g. vendor publishes “v2.4.x” while inventory says “2.04.05”) – normalise strings and validate against the vendor’s release table; (b) EOL devices that no longer appear in advisories – carry an internal **EOL-watch** list; (c) advisories without machine-readable affected ranges – triage by hand for those. Award marks for any two of these or equivalent.

Exercise 6.3 – When Active Scanning Wins

Passive monitoring only sees devices that talk on the wire during the capture window; silent spares, cold standbys, and assets behind a serial-to-Ethernet gateway are invisible. Banner / version detail is often inferred from protocol behaviour rather than observed directly, so firmware-level CVE matching can be ambiguous. Active probing fills both gaps and is sometimes the only way to confirm a specific patch level.

Scenario A – factory acceptance test (FAT) on a new skid before commissioning: the cell is not yet connected to production, so an aggressive Nmap + Tenable.ot active scan is safe; the safeguard is that nothing downstream depends on the skid yet.

Scenario B – post-incident forensics on an isolated cell: the cell has been segmented off after a suspected intrusion, so an active scan against the isolated VLAN cannot harm production; the safeguard is the segmentation itself plus a backup of PLC programs before scanning. Accept other defensible scenarios (planned outage firmware verification, lab reproduction of a customer bug, etc.).

Exercise 6.4 – Annotated Safe-nmap Command

```
nmap -sT -Pn -n --max-rate 5 --scan-delay 200ms \  
-p 102,502,20000,44818,20256 \  
--script s7-info 192.168.10.10
```

Annotations:

- **-sT** – full TCP connect; legacy ICS stacks mis-handle the SYN-only half-open scan of **-sS**.
- **-Pn** – skip ICMP host discovery; many PLCs reply oddly to ping and may drop subsequent traffic.
- **-n** – no DNS lookups; deterministic and quieter.
- **-max-rate 5** – cap to 5 packets per second; some controllers drop or crash above tens of packets per second.
- **-scan-delay 200ms** – explicit per-probe delay so a slow CPU has time to respond.
- **-p 102,502,20000,44818,20256** – Siemens S7, Modbus TCP, DNP3, EtherNet/IP, PC-Worx; the usual ICS suspects without sweeping unrelated ports.
- **-script s7-info** – one targeted NSE script for the vendor under test; do not run the full default script set.

Why not on production: even at this rate, the NSE script sends protocol-specific queries that some firmware versions parse incorrectly; a controller crash in a running cell is a process upset, possibly a safety event. Award marks if the student substitutes **modbus-discover** or **enip-info** for the matching target – one script, justified.

Exercise 6.5 – Read a Real CISA Advisory (rubric)

Award marks for the following extracted fields, regardless of which advisory the student chose:

- Correct full advisory ID (ICSA-YY-DDD-NN) and publication date.
- Vendor, product family, firmware band.
- All cited CWEs and the full CVSS v3.1 base vector and score.

- Both patch and non-patch mitigations (segmentation, default credential change, disabling web UI, etc.).
- Honest statement of patch availability: many advisories ship without firmware on day one – credit the student who notices.
- Sensible context comparison: a small water utility may lack the staffing for emergency patching but also runs a simpler attack surface; a tier-1 chemical site has more skilled defenders but more interconnections and higher safety consequence.

Penalise invented advisory IDs or URLs not in the CISA archive.

Exercise 6.6 – Spot the Misconception: Nessus on Tuesday

Three reasons the plan is bad:

1. Tuesday afternoon is normal production; even “safe checks” send unsolicited traffic, and legacy PLC TCP stacks (Modicon Quantum, S7-300, older Allen-Bradley) have crashed on unexpected flag combinations or fragmented probes.
2. Credentialed scans against HMIs can lock operator accounts after repeated login attempts, exactly when an operator needs to acknowledge an alarm.
3. Network discovery broadcasts can saturate small industrial switches and disrupt deterministic protocols (PROFINET, EtherNet/IP CIP) with millisecond timing budgets.

Alternative: deploy a passive monitor with a SPAN port (Claroty CTD, Nozomi Guardian, Microsoft Defender for IoT) to get the same inventory and vulnerability matching without injecting any traffic; reserve Nessus for the engineering subnet only, with vendor sign-off and a documented rollback. Accept “run active scans on a digital twin / mirror cell” as an equivalent answer.

Exercise 6.7 – Honeypots in OT

What Conpot is: an open-source low-/medium-interaction ICS honeypot maintained under the Honeynet Project. It emulates common industrial protocols out of the box – Modbus/TCP, S7Comm, IEC 60870-5-104, BACnet, HTTP, and SNMP – and ships templates that mimic specific devices such as a Siemens SIMATIC S7-200.

Placement: on the cell or process VLAN (Purdue L2/L3) using an unused IP that is documented as a honeypot only in the SOC’s asset register. Any TCP connection to it from the same VLAN is by definition unauthorised; place *nothing* else on that IP.

Catches: (i) lateral-movement scans by an attacker who already has a foothold in the cell, e.g. a worm sweeping Modbus port 502; (ii) careless internal scans by an unannounced contractor or vendor laptop. **Does not catch:** (i) a targeted attacker who fingerprints the device, notices it does not respond to vendor engineering protocol queries, and ignores it; (ii) attacks that bypass the network entirely, e.g. a malicious USB plugged into a real PLC on the same cell.

Exercise 6.8 – Patching Cadence: Schneider PLC

Compensating-control paragraph: restrict TCP/502 (and any Schneider-specific protocol ports) at the cell-zone firewall so that only the named engineering workstations can reach the affected Modicon; deploy an IPS or Tofino-class industrial firewall rule to drop the exploit pattern (vendor advisories usually include a signature); enable enhanced logging on the firewall and forward to the SOC; raise the alert threshold in Claroty CTD or Nozomi Guardian for any new client talking to that PLC; enforce application allow-listing and EDR on the engineering

workstations that can reach the cell; freeze controller program changes outside of two-person review for the next eight months.

Escalation paragraph: if any of the above cannot be implemented (e.g. no IPS in the path, no SOC ingestion, EDR incompatible with the engineering toolchain), the residual risk is no longer acceptable and the plant must either schedule an unplanned outage to apply the vendor patch, accept formal risk sign-off from the plant manager and the OT security lead against IEC 62443-2-1 / NIST SP 800-82 Rev. 3, or isolate the cell from any network reachable by the attacker. The acceptance decision must be documented with date, signatory, and a re-assessment trigger.

Exercise 6.9 – Researcher Drops a 0-Day on You

Step 1 (0–2 h): acknowledge the researcher in writing, thank them, and ask them to hold off public disclosure for a coordinated window. Do *not* run the supplied exploit code against any production charger; if you must validate, mirror the firmware on a lab device. Record the report in your case-tracking system.

Step 2 (2–8 h): loop in legal and your CISO; treat the report as sensitive. Confirm whether the vulnerability could be weaponised against your campus deployment specifically (model, firmware, network exposure). Begin drafting compensating controls (blocking the affected service at the firewall, disabling remote management).

Step 3 (8–24 h): contact Schneider PSIRT yourself via their published channel and forward the researcher's report (with their consent). Offer to act as a bridge so the researcher and vendor can coordinate. If consent is withheld, summarise the technical content for the vendor without revealing the reporter's identity.

Step 4 (24–48 h): agree a coordinated-disclosure timeline with researcher and vendor (typically 90 days under ISO/IEC 29147 or the FIRST PSIRT Services Framework). Document the timeline, notify affected internal stakeholders, and align on the public statement – do not publish unilaterally.

Exercise 6.10 – CWE-798 Hard-Coded Credentials in the Wild

Three examples (any three accepted from comparable advisories):

- *Siemens SIMATIC S7-1200 / S7-1500* – multiple advisories over the years citing CWE-798 on debug or web interfaces (e.g. Siemens SSA series advisories). Impact: device-level access for anyone with network reach.
- *Rockwell Automation MicroLogix / CompactLogix* – advisories citing hard-coded keys or default service credentials (ICSA series). Impact: code download or denial of service.
- *Moxa industrial switches / serial gateways* – recurring CWE-798 findings (e.g. ICSA-21-294-02 family). Impact: management plane takeover.

Accept any three real advisories. Penalise invented CVE numbers.

Organisation-level mitigation: treat *every* ICS management interface as if a hard-coded credential exists and enforce zero network reachability to those interfaces from outside the engineering VLAN. Concretely: deny TCP/80, TCP/443, Telnet and SSH to all cell-zone devices at the cell-zone firewall, require all management traffic to traverse a jump host with MFA and session recording, and alert (in Claroty CTD, Nozomi Guardian, Microsoft Defender for IoT, or equivalent) on any direct connection that bypasses the jump host. This neutralises CWE-798 even before the vendor ships a fix.